

Cybersecurity Daily Newsletter

Vol. 001 | 2026-05-20 07:00 WIB

Top 5 Highlights

- Torq acquires Jit.io to enhance AI-driven security operations
- CISA contractor's public GitHub repo exposed sensitive government credentials
- CVE-2026-34241 | Ctrlpanel-gg panel up to 1.1.x newmessage cross site scripting (GHSA-cmrr-q3hw-3vqh)
- CVE-2023-7345 | Ledger ledgerhq/hw-app-eth/Live up to 6.34.6 Data Message type conversion (EUVD-2023-60576)
- CVE-2024-36343 | AMD EPYC 4004 System Management Mode buffer underflow

Threat Intelligence (10)

01. Torq acquires Jit.io to enhance AI-driven security operations

Jit.io, founded in 2021, initially offered a security-as-code platform for developers, consolidating various application security and DevSecOps tools.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/torq-acquires-jit-io-to-enhance-ai-driven-security-operations>

02. CISA contractor's public GitHub repo exposed sensitive government credentials

The repository, named "Private-CISA" and maintained by contractor Nightwing, exposed AWS administrative credentials, access keys, tokens, plaintext usernames and passwords for internal CISA systems, and SSH keys.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/cisa-contractors-public-github-repo-exposed-sensitive-government-credentials>

03. CIRT insights: How to help prevent unauthorized account removals from AWS Organizations

The AWS Customer Incident Response Team works with customers to help them recover from active security incidents. As part of this work, the team often uncovers new or trending tactics used by various threat actors that take advantage of specific customer configurations and designs. Understanding these tactics can help inform your architecture decisions, imp...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://aws.amazon.com/blogs/security/cirt-insights-how-to-help-prevent-unauthorized-account-removals-from-aws-organizations/>

04. My Mother the Car, AI Slop, Nginx, Polyscope, Drupal, , GitHub, Aaran Leyland... - SWN #582

My Mother the Car, AI Slop, Nginx, Polyscope, Drupal, , GitHub, Aaran Leyland... - SWN #582

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/podcast-segment/15018-my-mother-the-car-ai-slop-nginx-polyscope-drupal-github-aaran-leyland-swn-582>

05. Discord rolls out end-to-end encryption on voice, video calls

Discord announced that all voice and video calls through the communication platform are now protected by default with end-to-end encryption (E2EE). [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/discord-rolls-out-end-to-end-encryption-on-voice-video-calls/>

06. SASE manages your network access, but who manages your SASE?

SASE adoption is easier than ever, but expertise gaps still create major security and access risks.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/perspective/sase-manages-your-network-access-but-who-manages-your-sase>

07. CISA Exposes Secrets, Credentials in 'Private' Repo

The agency's GitHub repository, publicly available since November 2025, was ironically named "Private-CISA."

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.darkreading.com/cybersecurity-operations/cisa-exposes-secrets-credentials-private-repo>

08. Stealer Spoofs Google, Microsoft & Apple, Then Backdoors macOS

The SHub Reaper stealer, which hides behind fake WeChat and Miro installers, marks a shift from ClickFix social engineering to Apple script-based execution.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/threat-intelligence/stealer-spoofs-google-microsoft-apple-backdoors-macos>

09. Microsoft Self-Service Password Reset abused in Azure data theft attacks

A threat actor targeting Microsoft 365 and Azure production environments is stealing data in attacks that abuse legitimate applications and administration features. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/microsoft-self-service-password-reset-abused-in-azure-data-theft-attacks/>

10. AntV data visualization tool the latest to be hit by ongoing npm supply chain attacks

The world's largest open-source registry, node package manager (npm), has been hit by another fast-moving malware attack, this time targeting the widely-used AntV enterprise data visualization tool. Unlike last week's high-profile npm attack on TanStack, which exploited a complex GitHub Actions cache poisoning weakness, the latest incident early on May 19...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.csoonline.com/article/4173291/antv-data-visualization-tool-the-latest-to-be-hit-by-ongoing-npm-supply-chain-attacks-2.html>

Latest Vulnerabilities (10)

01. CVE-2026-34241 | Ctrlpanel-gg panel up to 1.1.x newmessage cross site scripting (GHSA-cmrr-q3hw-3vqh)

A vulnerability was found in Ctrlpanel-gg panel up to 1.1.x . It has been rated as problematic . Affected by this vulnerability is an unknown functionality. Performing a manipulation of the argument newmessage results in cross site scripting. This vulnerability is cataloged as CVE-2026-34241...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuln.db.com/vuln/364750>

02. CVE-2023-7345 | Ledger ledgerhq/hw-app-eth/Live up to 6.34.6 Data Message type conversion (EUVD-2023-60576)

A vulnerability was found in Ledger ledgerhq, hw-app-eth and Live up to 6.34.6 . It has been declared as problematic . Affected is an unknown function of the component Data Message Handler . Such manipulation leads to incorrect type conversion. This

vulnerability is listed as CVE-2023-7345...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364749>

03. CVE-2024-36343 | AMD EPYC 4004 System Management Mode buffer underflow

A vulnerability was found in AMD EPYC 4004, EPYC 4005, Ryzen 6000 Processors with Radeon Graphics, Ryzen 7040 Mobile Processors with Radeon Graphics, Ryzen 7045 Mobile Processors with Radeon Graphics, Ryzen 7000 Desktop Processors, Ryzen 9000HX Mobile Processors, Ryzen AI MAX, Ryzen AI 300 Processors, Ryzen Threadripper 7000 Processors, Ryzen Threadripper P...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364748>

04. CVE-2026-5090 | TODDR Template::Plugin::HTML up to 3.102 on Perl HTML Attribute var HTML injection (Issue 327 / EUVD-2026-30995)

A vulnerability was found in TODDR Template::Plugin::HTML up to 3.102 on Perl and classified as problematic . This affects an unknown function of the component HTML Attribute Handler . The manipulation of the argument var results in HTML injection. This vulnerability is identified as CVE-2026-5090...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364747>

05. CVE-2025-15645 | Ledger Nano X/Flex/Stax up to 2.4.1 MCU Firmware Update reset_handler improper validation of specified quantity in input (EUVD-2025-209901)

A vulnerability has been found in Ledger Nano X, Flex and Stax up to 2.4.1 and classified as problematic . The impacted element is an unknown function of the component MCU Firmware Update Handler . The manipulation of the argument reset_handler leads to improper validation of specified quantity in input. This vulnerability is referenced as CVE-2025-15645...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364746>

06. CVE-2026-34246 | Ctrlpanel-gg panel up to 1.1.x Admin Role Management Interface RoleController.php datatable role cross site scripting (GHSA-wpqj-xwhq-2mmh / EUVD-2026-30986)

A vulnerability, which was classified as problematic , was found in Ctrlpanel-gg panel up to 1.1.x . The affected element is the function datatable of the file app/Http/Controllers/Admin/RoleController.php of the component Admin Role Management Interface...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364745>

07. CVE-2026-34358 | Ctrlpanel-gg panel up to 1.1.x PATCH Request store/update access control (GHSA-pxmw-gj52-9p68 / EUVD-2026-30993)

A vulnerability, which was classified as critical , has been found in Ctrlpanel-gg panel up to 1.1.x . Impacted is the function store/update of the component PATCH Request Handler . Performing a manipulation results in improper access controls. This vulnerability was named CVE-2026-34358...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364744>

08. CVE-2026-34463 | mantisbt Mantis Bug Tracker up to 2.28.1 Project Name bug_report_page.php cross site scripting (GHSA-fvjf-68wh-rwp2)

A vulnerability classified as problematic was found in mantisbt Mantis Bug Tracker up to 2.28.1 . This issue affects some unknown processing of the file bug_report_page.php of the component Project Name Handler . Such manipulation leads to cross site scripting. This vulnerability is uniquely identified as CVE-2026-34463...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364743>

09. CVE-2026-34390 | mantisbt Mantis Bug Tracker up to 2.28.1 Custom Fields manage_proj_user_add.php access control (GHSA-frf7-jhp9-jxm6)

A vulnerability classified as critical has been found in mantisbt Mantis Bug Tracker up to 2.28.1 . This vulnerability affects unknown code of the file manage_proj_user_add.php of the component Custom Fields Handler . This manipulation causes improper access controls. This vulnerability is handled as CVE-2026-34390...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364742>

10. CVE-2026-34234 | Ctrlpanel-gg panel up to 1.1.x os command injection (GHSA-jmhr-q9q5-fqwh)

A vulnerability described as critical has been identified in Ctrlpanel-gg panel up to 1.1.x . This affects an unknown part. The manipulation results in os command injection. This vulnerability is known as CVE-2026-34234 . It is possible to launch the attack remotely. No exploit is available. Upgrading the affected component is recommended.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/364741>

Data Breach & Cybercrime (10)

01. Microsoft shuts down illegal code-signing operation used by ransomware crims to mask their malware

'Thousands' of US victims, including 12+ machines owned and operated by Redmond

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.theregister.com/security/2026/05/19/microsoft-disrupts-alleged-malware-signing-operation-used-by-ransomware-gangs/5243013>

02. Cybercrime service disrupted for abusing Microsoft platform to sign malware

Microsoft says it has disrupted a malware-signing-as-a-service (MSaaS) operation that abused the company's Artifact Signing service to generate fraudulent code-signing certificates used by ransomware gangs and other cybercriminals. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/cybercrime-service-disrupted-for-abusing-microsoft-platform-to-sign-malware/>

03. FBI: Americans lost over \$388 million to scams using crypto ATMs in 2025

The FBI says Americans have lost over \$388 million last year to scams using cryptocurrency kiosks, also known as crypto ATMs or Bitcoin ATMs. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/fbi-americans-lost-over-388-million-to-scams-using-crypto-atms-in-2025/>

04. Trapdoor Android Ad Fraud Scheme Hit 659 Million Daily Bid Requests Using 455 Apps

Cybersecurity researchers have disclosed details of a new ad fraud and malvertising operation dubbed Trapdoor targeting Android device users. The activity, per HUMAN's Satori Threat Intelligence and Research Team, encompassed 455 malicious Android apps and 183 threat actor-owned command-and-control (C2) domains, turning the infrastructure into a pipeline for...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/05/trapdoor-android-ad-fraud-scheme-hit.html>

05. Microsoft Disrupts Malware-Signing Service Run by 'Fox Tempest'

Fox Tempest provides a service that cybercriminals use to distribute ransomware and other malware disguised as legitimate software. The post Microsoft Disrupts Malware-Signing Service Run by 'Fox Tempest' appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.securityweek.com/microsoft-disrupts-malware-signing-service-run-by-fox-tempest/>

06. Biometrics, diagnoses, and bank details exposed in major healthcare breach

NYC Health + Hospitals says attackers accessed its systems for months through a third-party vendor compromise, affecting at least 1.8 million people.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/news/2026/05/biometrics-diagnoses-and-bank-details-exposed-in-major-healthcare-breach>

07. Exposing Fox Tempest: A malware-signing service operation

Fox Tempest is a financially motivated threat actor operating a malware-signing-as-a-service (MSaaS) used by other cybercriminals, including Vanilla Tempest and Storm groups, to more effectively distribute malicious code, including ransomware. The post Exposing Fox Tempest: A malware-signing service operation appeared first on Microsoft Security Blog .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/05/19/exposing-fox-tempest-a-malware-signing-service-operation/>

08. Microsoft Takes Down Fox Tempest for Providing Ransomware-Enabling Signing Tool

Microsoft's Digital Crimes Unit has taken down the infrastructure of Fox Tempest, a prolific cybercrime-enabling threat group

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/microsoft-takes-down-fox-tempest/>

09. 7-Eleven confirms data breach claimed by the ShinyHunters gang

Convenience store chain giant 7-Eleven confirmed that its systems were breached in a cyberattack claimed by the ShinyHunters extortion group last month. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/7-eleven-confirms-data-breach-claimed-by-the-shinyhunters-gang/>

10. A 6-step guide for responding to the Foxconn ransomware/supply chain incident

Here's how to develop a more effective response to supply chain attacks.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/perspective/a-6-step-guide-for-responding-to-the-foxconn-ransomware-supply-chain-incident>